

Enterprise GRC Common Control Mapping & Assurance Assessment

Common Controls • Cross-Framework Mapping • Evidence • Assurance

ENTERPRISE GRC PROFESSIONAL CASE STUDY

Prepared by [Nouman J.](#)

GRC Operating Model • Risk • Controls • Regulatory Compliance

1. Executive Summary

This synthetic enterprise case study models a common-control operating model that maps security, privacy, resilience and governance requirements across multiple frameworks. The objective is to reduce duplicated control activity while preserving framework-specific accountability and evidence.

Overall Risk Posture

HIGH. The assessment identifies material governance and control exposure requiring accountable treatment. Risk is concentrated in the framework-specific domains below and should be managed through measurable remediation rather than documentation alone.

Management Priorities

01 — Confirm accountable ownership. 02 — Close critical control gaps. 03 — Test operational effectiveness. 04 — Improve evidence traceability. 05 — Embed recurring management reporting.

2. Business Context & Scope

A fictional enterprise is subject to multiple regulatory and management-system requirements. Different teams operate overlapping controls, evidence repositories and assurance activities. The assessment designs a common control layer with accountable owners and traceable evidence.

Assessment Scope

The case study covers governance, risk, controls, evidence, operational effectiveness, third-party dependencies where relevant, remediation and management reporting. The scenario is synthetic and does not use real client information.

3. Governance & Accountability

Role	Primary Accountability	Evidence / Decision
Board / Executive Management	Risk appetite, material risk acceptance and oversight	Management review; risk acceptance
GRC / Framework Owner	Methodology, challenge, mapping and reporting	Risk register; control assessment
Business / Service Owner	Operational risk and control execution	Control evidence; remediation
Security / Privacy / IAM / Resilience	Specialist control design and monitoring	Technical or privacy evidence
Third-Party Risk	Supplier risk and oversight where applicable	Assessments; contracts; reviews
Internal Audit	Independent assurance	Audit testing; findings

4. Assessment Methodology

Likelihood (L) and Impact (I) are scored from 1–5. **Inherent Risk = L × I.** Risk bands: 1–4 Low, 5–9 Moderate, 10–14 High, 15–25 Critical. Residual risk reflects exposure after controls and treatment. Control effectiveness is assessed through design, operating evidence and repeatability.

Assessment Logic

Identify → Assess → Control → Evidence → Test → Treat → Monitor → Improve.

5. Control Domains

Control Domain	What is assessed	Typical Evidence
Common control ownership	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review
Cross-framework mapping	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review
Control rationalisation	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review
Evidence-as-a-control operating model	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review

Control Domain	What is assessed	Typical Evidence
Risk and control linkage	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review
Regulatory change	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review
Testing and assurance	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review
Management reporting	Governance, ownership, risk treatment and operating effectiveness	Policy / register / test evidence / management review

6. Detailed Risk Register

ID	Risk Scenario	Affected Area	L	I	Inherent	Level	Primary Treatment	Residual	Owner
GRC-01	Duplicate controls create inconsistent assurance	Control Model	4	3	12	High	Common control taxonomy and ownership	6	GRC
GRC-02	Control evidence cannot be reused reliably	Evidence	4	4	16	Critical	Metadata / evidence-as-a-control operating model	8	GRC / Control Owners
GRC-03	Control owners are unclear across frameworks	Governance	3	4	12	High	Common control owner council	6	GRC
GRC-04	Regulatory change is not translated into controls	Regulatory	3	5	15	Critical	Regulatory change intake and mapping	8	Compliance
GRC-05	Testing is duplicated across assurance functions	Assurance	4	3	12	High	Integrated assurance plan	6	Audit / GRC
GRC-06	Exceptions are tracked differently by framework	Exceptions	3	4	12	High	Central exception model	6	GRC
GRC-07	Management reporting lacks common risk language	Reporting	3	3	9	Moderate	Enterprise risk taxonomy and dashboard	4	ERM / GRC

Risk Themes

The register is designed to show how framework requirements translate into enterprise risk scenarios, accountable owners, treatment decisions and measurable residual exposure.

7. Control Effectiveness & Gap Analysis

Finding	Area	Severity	Observation	Recommended Action
F-01	Control Ownership	High	Common controls are mapped to several frameworks without consistent ownership.	Establish a common control owner council and accountability model.
F-02	Evidence	High	Evidence metadata and reuse standards differ between teams.	Implement a metadata / evidence-as-a-control operating model.
F-03	Regulatory Change	High	New requirements are not always translated into existing control language.	Create a regulatory change-to-control mapping workflow.
F-04	Assurance	Medium	Internal audit, compliance and security testing can duplicate effort.	Introduce a coordinated integrated assurance plan.
F-05	Exceptions	Medium	Exception records use different severity and expiry conventions.	Create one enterprise exception taxonomy and workflow.

8. Evidence & Assurance

Evidence should demonstrate that a control exists, has an accountable owner, operates at the required frequency and produces traceable results. Exceptions should carry an owner, rationale, expiry date and risk decision.

Minimum Evidence Set

Risk register • control inventory • ownership/RACI • policies and procedures • control test results • exceptions • remediation tracker • management review records • supplier evidence where applicable.

9. Operational / Regulatory Considerations

A common GRC model should connect incidents and control failures back to affected requirements, risks, owners and evidence. This creates a traceable assurance chain rather than treating each framework as a separate compliance silo.

Assurance Principle

The organisation should be able to move from requirement → risk → control → evidence → test result → remediation without losing traceability.

10. Remediation Roadmap

Phase	Priority Actions	Owner	Expected Outcome
0–30 days	Define common control taxonomy, owners and framework inventory.	GRC / Compliance	Common control baseline
31–90 days	Map priority controls across GDPR, NIS2, DORA, ISO 27001 and ISO 42001.	GRC / Control Owners	Reduced duplication
91–180 days	Implement evidence metadata, integrated assurance and exception governance.	GRC / Audit	Reusable assurance evidence
181–365 days	Automate regulatory change mapping and management dashboards.	GRC / Compliance	Scalable GRC operating model

11. KPI / KRI Management Dashboard

Metric	Target	Red Threshold	Management Signal
Critical controls with accountable owner	100%	<95%	RED
Priority controls with reusable evidence	>90%	<80%	AMBER
Framework requirements mapped to common controls	>95%	<90%	RED
Assurance activities coordinated through plan	100%	<90%	AMBER
Expired exceptions without action	0	>0	RED

Management Interpretation

Red signals require accountable management action or formal risk acceptance. Amber signals require a defined remediation plan and recurring monitoring. Targets are illustrative portfolio thresholds, not legal or regulatory limits.

12. Management Reporting

The management view should focus on risk exposure, control effectiveness, overdue remediation, exceptions and trend direction. Reporting should be concise enough for executive review while retaining drill-down evidence for control owners.

13. Continuous Improvement

The operating model closes the loop through recurring risk reassessment, control testing, lessons learned, regulatory change, incident analysis and management review. Material changes should trigger reassessment rather than waiting for the annual cycle.

14. Executive Decision Requests

1. Confirm accountable owners for all critical risks and controls.
2. Prioritise critical findings and define target dates.
3. Require evidence-based control effectiveness reporting.
4. Review unresolved high residual risks and formal exceptions.

15. Professional Capability Demonstrated

Enterprise risk assessment • Governance and accountability • Control design and testing • Regulatory interpretation • Evidence governance • Remediation planning • KPI/KRI reporting • Executive communication

16. Management Conclusion

The principal value of a common-control model is not fewer documents; it is consistent ownership, reusable evidence and comparable risk decisions across frameworks. Governance should remain centralised while control execution stays accountable to the operational owner.

17. Portfolio Disclaimer

Synthetic professional case study for portfolio demonstration. It does not represent a real client engagement, regulatory filing, audit opinion, certification or production implementation.